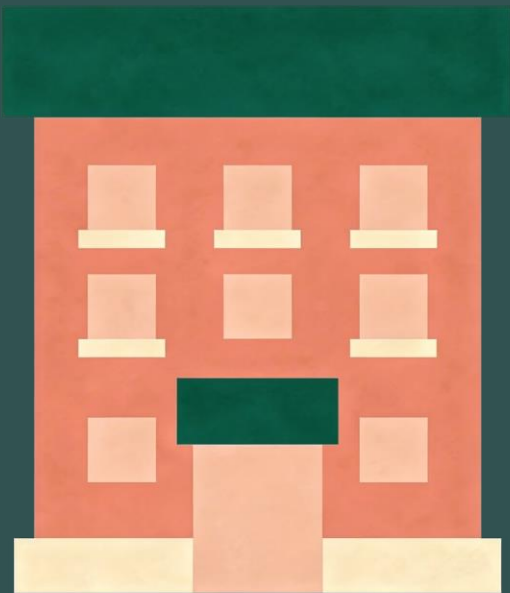




Week 5: Monitoring & Control

Establishing ongoing vendor oversight at **Johns Hopkins Hospital** — building the systems, dashboards, and contract controls that keep patient data protected.

TPRM PROGRAM

WEEK 5 OF 8



This Week's Mission



Healthcare Compliance Tracker

Track HIPAA risk assessments, SOC 2 / HITRUST renewals, and BAA status across all vendors



TPRM KPI Dashboard

Visualize vendor compliance rates, high-risk open items, and overdue remediation in real time



Contract Review

Audit vendor contracts for breach notification timelines, data ownership, and right-to-audit clauses

Healthcare Compliance Tracker

A centralized tracker ensuring no critical deadline or certification gap goes unnoticed.

Vendor	HIPAA Risk Assessment	SOC 2 Renewal	HITRUST Renewal	BAA Status
Epic Systems	Jan 15, 2025	Mar 2025	Jun 2025	✅ Signed
Cerner/Oracle	Feb 3, 2025	Apr 2025	Aug 2025	✅ Signed
Philips HealthSuite	Mar 10, 2025	⚠️ Overdue	Sep 2025	⚠️ Pending
Change Healthcare	⚠️ Overdue	May 2025	⚠️ Overdue	✅ Signed
Nuance (Microsoft)	Apr 22, 2025	Jun 2025	Dec 2025	✅ Signed

⚠️ Vendors marked ⚠️ require immediate outreach and remediation scheduling before next audit cycle.

TPRM KPI Dashboard

Real-time visibility into vendor risk posture — built in Excel or Eramba.

78%

HIPAA Compliant

Vendors meeting full HIPAA requirements

6

High-Risk Open

Vendors with unresolved critical findings

14

Overdue Items

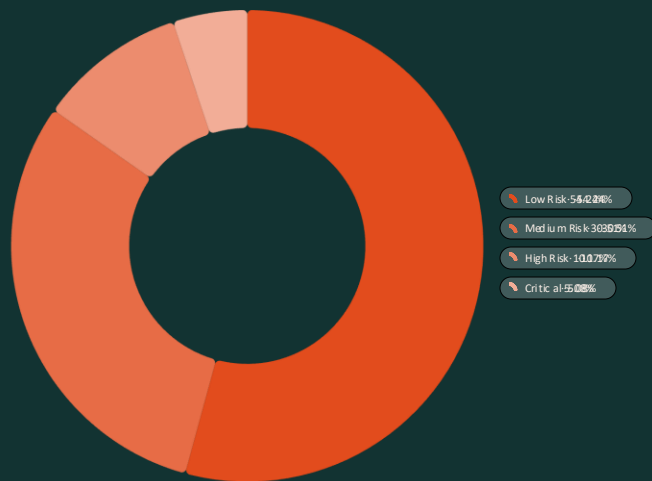
Remediation tasks past their due date

92%

BAA Coverage

Vendors with active signed agreements

KPI Dashboard — Risk Breakdown



Risk Distribution — 59 Active Vendors

The majority of Johns Hopkins vendors fall into low-to-medium risk. However, **9 vendors require urgent action** — 6 high-risk and 3 critical.

● Critical (3)

Immediate escalation to CISO required

● High Risk (6)

Remediation plan due within 30 days

● Medium (18)

Quarterly review scheduled

Contract Review – 3 Critical Clauses

1

Breach Notification Timeline

HIPAA requires 60-day notification. Review contracts for **shorter internal SLAs** (recommend 24-72 hrs for JHH).

2

Patient Data Ownership

Confirm **JHH retains full ownership** of all patient data. Vendors must not retain, sell, or use data post-contract.

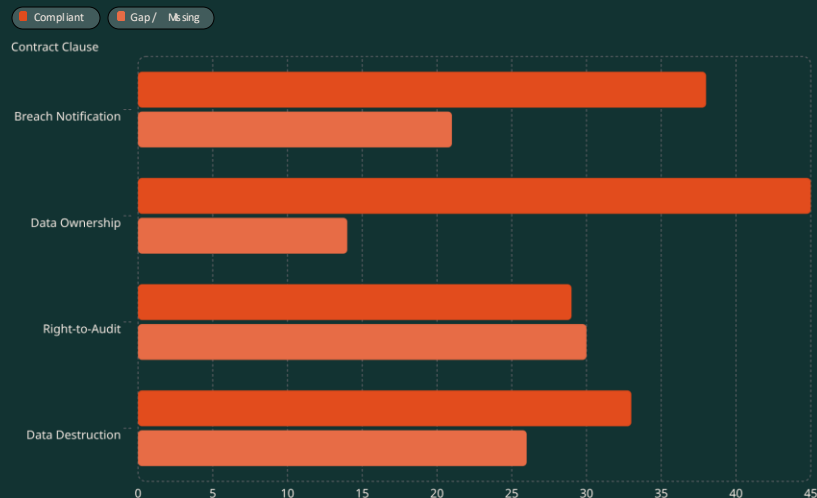
3

Right-to-Audit Clause

Ensure JHH has explicit right to audit vendor security controls – **annually at minimum**, with notice provisions.



Contract Findings — Current State



Key Insight

Right-to-audit is the most common gap — missing in 51% of vendor contracts reviewed.

Breach notification timelines also need tightening: most contracts cite 60 days, far exceeding JHH's internal 72-hour target.



Priority: Renegotiate top 10 high-risk vendor contracts by end of Q2 2025.

Contract Improvement Recommendations



Identify Gaps

Prioritize Risk

Renegotiate
Terms

Re-execute &
Track

Prioritize renegotiation with high-risk and critical vendors first. Use a standardized JHH contract addendum to enforce consistent HIPAA language, breach notification SLAs, and audit rights across all third-party agreements.

Week 5 Deliverables



KPI Dashboard

Excel or Eramba-based. Live view of HIPAA compliance %, high-risk vendors, and overdue remediation.



Compliance Tracker

Master log of all HIPAA assessment dates, SOC 2 / HITRUST renewals, and BAA status by vendor.



Contract Improvement Report

Gap analysis across 59 vendors with prioritized recommendations and model contract language.



All three deliverables are due by end of Week 5. Present findings to the Vendor Risk Committee in the Week 6 review session.

Looking Ahead — Week 6

From monitoring to action: Week 6 focuses on **vendor remediation management** and escalation protocols.

- Present KPI Dashboard to CISO & Compliance Committee
- Issue formal remediation notices to 9 high-risk / critical vendors
- Begin contract renegotiation with top 10 priority vendors
- Schedule right-to-audit exercises for Q2 2025

